Management Review & Correctieve Maatregelen

ISO 27001:2022 — Clause 9.3, 10.1, 10.2

Documentnummer	ISMS-022
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam CISO / Verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

DEEL A — Management Review (Clause 9.3)

1. Doel

De managementreview is een periodieke directiebeoordeling van het ISMS om te waarborgen dat het geschikt, adequaat en effectief blijft. Het is een verplicht onderdeel van ISO 27001:2022 en essentieel voor continue verbetering.

2. Frequentie en deelnemers

Frequentie	Minimaal jaarlijks; bij voorkeur halfjaarlijks
Voorzitter	Directie / Bestuurder
Vaste deelnemers	Directie, CISO, IT-beheer
Optionele deelnemers	HR, juridisch, externe adviseur
Notulist	CISO of aangewezen notulist

3. Verplichte input (Clause 9.3)

De CISO bereidt de volgende input voor:

#	Input	Bron
1	Status van acties uit vorige managementreviews	Notulen vorige review
2	Wijzigingen in interne en externe context	ISMS Scope (ISMS-001)
3	Wijzigingen in behoeften en verwachtingen van belanghebbenden	Stakeholderanalyse
4	Informatiebeveiligingsprestaties, waaronder:	
4a	— Non-conformiteiten en correctieve maatregelen	CAPA-register
4b	— Monitoring- en meetresultaten	KPI-rapportage
4c	— Auditresultaten	Interne auditrapporten (ISMS-021)
4d	— Realisatie van doelstellingen	Doelstellingen (ISMS-003)
5	Feedback van belanghebbenden	Klachtenoverzicht, klantaudits
6	Resultaten van risicobeoordeling en status risicobehandeling	Risicoregister (ISMS-005)
7	Kansen voor verbetering	Input van alle deelnemers

4. Verplichte output (besluiten)

De managementreview resulteert in besluiten over:

#	Output	Vastlegging
1	Mogelijkheden voor continue verbetering	Actielijst met eigenaar en deadline
2	Noodzaak tot wijziging van het ISMS	Beschrijving wijzigingen
3	Benodigde middelen	Budget- en personeelsbeslissingen
4	Risicoacceptaties	Ondertekening door directie
5	Bijstelling van doelstellingen (indien nodig)	Update ISMS-003

5. Notulen-template

Management Review Notulen

Datum	[DD-MM-JJJJ]
Locatie	[Kantoor / Online]
Aanwezig	[Namen en functies]

Afwezig	[Namen en functies]
Notulist	[Naam]

Agendapunten en bespreking:

#	Agendapunt	Bespreking	Besluit / Actie	Eigenaar	Deadline
1	Status acties vorige review	[Samenvatting]	[Besluit]	[Naam]	[Datum]
2	Wijzigingen context en stakeholders	[Samenvatting]	[Besluit]	[Naam]	[Datum]
3	ISMS-prestaties en KPI's	[Samenvatting]	[Besluit]	[Naam]	[Datum]
4	Auditresultaten	[Samenvatting]	[Besluit]	[Naam]	[Datum]
5	Incidentoverzicht	[Samenvatting]	[Besluit]	[Naam]	[Datum]
6	Risicobeoordeling update	[Samenvatting]	[Besluit]	[Naam]	[Datum]
7	Doelstellingen evaluatie	[Samenvatting]	[Besluit]	[Naam]	[Datum]
8	Verbetermogelijkheden	[Samenvatting]	[Besluit]	[Naam]	[Datum]
9	Middelen en budget	[Samenvatting]	[Besluit]	[Naam]	[Datum]

Volgende managementreview gepland op: [DD-MM-JJJJ]

Handtekening voorzitter: _____ **Datum:** _____

DEEL B — Correctieve Maatregelen (Clause 10.1, 10.2)

6. Doel

Deze procedure beschrijft hoe [Organisatienaam] non-conformiteiten identificeert, analyseert en corrigeert om herhaling te voorkomen. Correctieve maatregelen zijn onderdeel van de PDCA-cyclus (Plan-Do-Check-Act).

7. Wanneer worden correctieve maatregelen geïnitieerd

- Non-conformiteiten uit interne of externe audits
- Beveiligingsincidenten met structurele oorzaak
- Niet-behaalde doelstellingen
- Klachten of feedback van klanten of belanghebbenden

- Bevindingen uit managementreviews
- Afwijkingen geconstateerd tijdens dagelijkse operatie

8. Correctief actieproces

CAPA-cyclus (Corrective and Preventive Action)

Van identificatie tot structurele borging · sluit aan op Plan-Do-Check-Act

Stap	Actie	Verantwoordelijke
1	**Identificatie:** Non-conformiteit registreren in het CAPA-register	Melder / Auditor / CISO
2	**Directe correctie:** Indien nodig, onmiddellijke actie om de gevolgen te beperken	Proceseigenaar
3	**Oorzaakanalyse:** Onderliggende oorzaak bepalen (5x Waarom, Ishikawa, of andere methode)	CISO + Proceseigenaar
4	**Correctieve maatregel:** Structurele maatregel definiëren om herhaling te voorkomen	CISO + Proceseigenaar
5	**Implementatie:** Maatregel uitvoeren binnen de gestelde deadline	Eigenaar maatregel
6	**Verificatie:** Controleren of de maatregel effectief is (na implementatie)	CISO
7	**Afsluiting:** Non-conformiteit afsluiten en documenteren	CISO

9. CAPA-register (Corrective and Preventive Action)

ID	Datum	Bron	Beschrijving non-conformiteit	Directe correctie	Oorzaakanalyse	Correctieve maatregel	Eigenaar
CAPA-001	[Datum]	[Audit/ Incident/ Review]	[Beschrijving]	[Actie]	[Root cause]	[Structurele maatregel]	[Naam]
CAPA-002							

10. Oorzaakanalyse methoden

10.1 5x Waarom

Niveau	Vraag	Antwoord
Waarom 1	Waarom is [het probleem] opgetreden?	[Antwoord]
Waarom 2	Waarom [antwoord 1]?	[Antwoord]
Waarom 3	Waarom [antwoord 2]?	[Antwoord]
Waarom 4	Waarom [antwoord 3]?	[Antwoord]
Waarom 5	Waarom [antwoord 4]?	→ **Root cause**

10.2 Voorbeeld

Niveau	Vraag	Antwoord
1	Waarom was het systeem kwetsbaar?	De patch was niet geïnstalleerd
2	Waarom was de patch niet geïnstalleerd?	Het patchproces had het niet opgepikt
3	Waarom had het patchproces het niet opgepikt?	De vulnerability scanner was niet geconfigureerd voor dit systeem
4	Waarom was de scanner niet geconfigureerd?	Het systeem was recent toegevoegd en niet opgenomen in het asset register
5	Waarom was het niet opgenomen?	Er is geen proces voor automatische registratie bij ingebruikname
→	**Root cause**	Ontbrekend proces voor asset-registratie bij ingebruikname nieuwe systemen

11. Monitoring en rapportage

- Open CAPA's worden maandelijks gereviewed door de CISO
- Overzicht van CAPA's wordt besproken in de managementreview
- KPI: percentage CAPA's afgesloten binnen deadline (doel: ≥90%)
- Trend-analyse: terugkerende oorzaken worden geïdentificeerd

12. Registraties

Registratie	Bewaartermijn
Management review notulen	3 jaar
CAPA-register	3 jaar na afsluiting
Oorzaakanalyses	3 jaar

13. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]